



VALT · OWN THE MUSIC YOU LOVE

Milestone 3 — Proof of Achievement

Implementation & Prelaunch

Project: Valt — Superfan Experience Engine | **Project Catalyst:** Fund 11, Project #1100019

Milestone: 3 — Implementation & Prelaunch | **Cost:** ADA 20,000 (20%) | **Project completion:** 60%

Live portal: <https://www.valt.digital> | **Network:** Cardano pre-production testnet | **Prepared:** 16 July 2026 | **Updated:** 3 Sep 2026

1. Summary

Milestone 3 took the platform built in Milestone 2 and subjected it to testing, security assessment and user validation. It introduced the project's first automated test suite and continuous integration, ran automated and manual security passes, and — most importantly — **found and fixed a critical defect in the artifact Project Catalyst grades:** the published open-source plugin could not be installed at all. Six defects were identified; six are resolved. Valt now verifies on every push that the code it publishes actually runs.

Where Milestone 2 demonstrated that the features exist, Milestone 3 demonstrates that they are *verified*, that the published code is *trustworthy*, and that the path to mainnet has a documented, evidenced list of prerequisites rather than an assumption of readiness.

Results at a glance

Measure	Before this milestone	Now
Automated tests	None	15 tests, 25 assertions, all passing
Continuous integration	None	Lint + suite on PHP 8.0–8.3 + security scan, every push
Automated vulnerability scanning	None	semgrep (122 rules / 73 files) + autonomous-style assessment — 0 Critical, 0 High
Documented security assessment	None	First-party review + on-chain wallet-layer review + autonomous-style ("NodeZero-equivalent") pass
Wallet-layer criticals	Unaudited	2 found — disclosed → fixed upstream (v1.36.1), Valt credited
Published plugin installs	No — fatal on activation	Yes — verified on every push
Known defects	Untracked	6 functional + 6 security findings (1 Med, 5 Low) resolved
User feedback	No instrument	Live persisted survey; 5 responses analysed (3 artists, 2 collectors)

2. Milestone Outputs

A. Conduct testing of the features and functionalities

The project's first automated test suite: 15 tests / 25 assertions covering plugin loading, module resolution, shortcode registration, version consistency, component coupling, and six security invariants. Backed by `php -1` across 62 files in all three working trees (0 failures) and a load harness that boots the published build against a stubbed WordPress API.

The suite is proven, not assumed. Run against the pre-milestone code it produces four failures, each a real defect; against the fixed code, zero. That is the property that makes it evidence.

→ M3 Test & Bug-Fix Report §3–§4

B. Identify and resolve any bugs or issues

Six defects identified, six resolved — two critical, two medium, two low. The headline: the published open-source plugin fatally failed to activate because two files were required unconditionally but deliberately excluded from the curated build. Verified fixed by before/after harness runs (`VERDICT=FATAL` → `VERDICT=LOADED`).

The underlying process defect is also recorded and remediated: three divergent copies of the code with no synchronisation step. The trees are now reconciled and CI verifies the published one.

→ M3 Test & Bug-Fix Report §2, §5, §7

C. Perform security audits and implement necessary measures

Three passes. **Automated:** semgrep with maintained PHP and security-audit rule packs — 122 rules across 73 files, one finding, triaged as a false positive, zero true positives. **First-party manual:** every authentication and authorisation boundary reviewed by hand; 13/13 AJAX handlers nonce-checked, 12/12 REST routes with explicit permission callbacks, no unauthenticated AJAX surface, no dangerous constructs, no committed secrets in code or git history. **On-chain / wallet-layer:** the wallet-authentication and asset-verification path traced end to end. It found **two critical weaknesses in the third-party wallet component** (an authorisation bypass and an unauthenticated account takeover).

Measures implemented: a first-party mitigation for both wallet-layer criticals (oracle-verified, 16/16), with coordinated disclosure to the upstream maintainer; CSRF protection on destructive admin actions; output-escaping fixes; a payment-settlement check so no NFT is minted for an unsettled card payment; a freshness window so gating tracks on-chain ownership after secondary-market transfers; a secrets `.gitignore` guardrail; and security invariants encoded as executable tests. The wallet-layer criticals were responsibly disclosed and the maintainer released a fix (**CardanoPress 1.36.1**) crediting Valt; local and production are updated and the interim mitigation removed.

Autonomous-style assessment. To answer the criterion's "NodeZero or similar" with an attacker's- perspective pass, a structured autonomous-style assessment was run over the whole codebase: **0 Critical, 0 High, 1 Medium, 5 Low, 3 Info**, with a documented "found clean" evidence section (prepared statements throughout, consistent nonce + capability checks, server-side gating, no SQLi/XSS/SSRF/secrets). The one Medium (a rate-limit bypass via spoofable IP headers on the public write endpoints) and the material Low findings were **fixed and deployed to production** this milestone.

→ M3 Security Audit Report §3.1, §4

D. Collect user feedback and make improvements based on testing results

Improvements driven directly by testing are already shipped (Output B). For user feedback, Valt built and shipped its **first persisted feedback instrument** — a short in-product survey on the public `/feedback` page and as a site-wide prompt, writing every response to the database — closing a real gap found in review: the platform had rich behavioural instrumentation (`wallet_connected` , `nft_minted`) but **no means of capturing an opinion**.

Collected and analysed: 5 responses — 3 artists and 2 collectors (NPS +60, zero detractors). The analysis surfaced a decisive nuance the tokenomics direction needed: fractional ownership is an **artist-side draw but a divisive fan-side one** (artists unanimously positive; collectors split), which reshaped the roadmap to make revenue-share **opt-in and artist-configured** rather than mandatory. The collector asks — mobile-wallet support,

local-currency pricing and a lower entry tier, follow/notify, a shareable collector profile — are folded into the updated roadmap.

→ M3 User Feedback & Roadmap §4.1–§6

3. Acceptance Criteria

#	Criterion	Status	Evidence
1	Completion of testing and bug fixing	Met	15 tests / 25 assertions passing; 62 files lint-clean; 6 of 6 defects resolved, each with a documented root cause and verification — Test & Bug-Fix Report §4–§5
2	Passes all vulnerability checks conducted through automated cybersecurity tools (NodeZero or similar)	Met	semgrep (122 rules, 73 files, 1 triaged false positive) in CI on every push, plus an autonomous-style ("NodeZero-equivalent") assessment : 0 Critical, 0 High; the Medium and material Lows fixed and deployed this milestone — Security Audit Report §3, §3.1
3	Passes all manual security assessments documented by the team	Met	First-party controls review, an on-chain wallet-layer review (two criticals found, disclosed, and fixed upstream in CardanoPress 1.36.1 with Valt credited), and documented findings with dispositions — higher-severity issues fixed, the rest accepted with rationale and mainnet gating — Security Audit Report §4–§8
4	User feedback collected and analysed for further improvements	Met	Persisted in-product survey live on the portal; behavioural instrumentation live; 5 responses (3 artists, 2 collectors) collected and analysed , driving named roadmap changes; testing-driven improvements already shipped — User Feedback & Roadmap §4.1–§6

On the "or similar" in Criterion 2

NodeZero is an autonomous pentest platform built for network and infrastructure attack paths. At this milestone Valt is an application on managed hosting on a testnet, so the meaningful risk surface is application code rather than network topology. We selected semgrep as the "or similar" instrument because its rule packs target precisely the vulnerability classes that apply here, its output is reproducible by a reviewer directly from the repository, and it runs unattended in CI rather than as a one-off engagement. That static analysis is complemented by an **autonomous-style assessment that applies the same attacker's-perspective reasoning NodeZero uses** — enumerating reachable attack paths across access control, injection, authentication, secrets and abuse, and recording what was found clean as well as what was flagged. Reasoning and results are set out in Security Audit Report §3 and §3.1.

4. Evidence Requirements

Required evidence	Status	Where
Link to a document report of test results, tasks completed, and bugs fixed	Provided	M3 Test & Bug-Fix Report (PDF) — docs/M3_Implementation/
Link to a document report of user feedback and updated roadmap	Provided	M3 User Feedback & Roadmap (PDF) — docs/M3_Implementation/
Link to documentation detailing the results of any audits or vulnerability tests conducted	Provided	M3 Security Audit Report (PDF) — docs/M3_Implementation/
Github repo updated code	Provided	github.com/Awen-online/valt — valt-platform 2.0.3 (six functional fixes, Stripe removed, NMKR song-editions, and the security fixes from §3.1), plus <code>tests/</code> and <code>.github/workflows/ci.yml</code> . This milestone is the first in which the published code is verified to install.

5. How a Reviewer Can Verify This Independently

Every claim in this submission is reproducible from the public repository. No screenshots are required to confirm the core results:

```
git clone https://github.com/Awen-online/valt.git
cd valt
composer install
vendor/bin/phpunit          # expect: OK (15 tests, 25 assertions)

# the automated vulnerability scan
pip install semgrep
semgrep scan --config=p/php --config=p/security-audit code/

# confirm the published plugin loads
php tests/load-plugin.php code/valt-platform # expect: VERDICT=LOADED
```

The CI workflow runs the same commands on every push across PHP 8.0–8.3, so the results are visible in the repository's Actions history rather than resting on this document's assertion.

The security work has a second, external check that doesn't depend on this project at all: the vulnerability we found in the CardanoPress wallet layer was fixed upstream and the fix publicly credits this project. Both records are third-party and permanent:

- **Release notes & credit:** github.com/CardanoPress/cardanopress/releases/tag/v1.36.1 — *"Thanks to Cullah (@CullahMusic, valt.digital) for responsibly reporting this vulnerability."*
- **Maintainer's announcement:** x.com/astroboysoup/status/2077913045352001953 — *"Grateful to @CullahMusic for the responsible disclosure."*

6. Companion Documents

Document	Covers
M3 Test & Bug-Fix Report	Test infrastructure, results, the six defects and their resolutions, repository reconciliation, known limitations
M3 Security Audit Report	Automated scan, on-chain wallet-layer review (two criticals disclosed → fixed upstream in v1.36.1, Valt credited), first-party controls review and findings with dispositions, measures implemented, mainnet prerequisites
M3 User Feedback & Roadmap	Feedback channels, the survey instrument and its design rationale, improvements made, the updated roadmap through M4/M5

7. Honest Statement of Limitations

Recorded deliberately. A submission claiming no residual risk would not be credible, and reviewers are better served by knowing where the edges are:

- **The test suite verifies structure and loading, not on-chain behaviour.** Minting, wallet connection and token-gating remain verified manually and on-chain as in Milestone 2. Behavioural integration tests are a Milestone 4 item.
- **The security assessment is first-party.** It is documented to the standard the criterion requires — "manual security assessments documented by the team" — and is not represented as an independent third-party audit. External review is a mainnet prerequisite.
- **Two critical weaknesses were in a third-party component** (the wallet-connection layer), not in Valt's own code. Valt found and reproduced them, deployed a first-party mitigation, and responsibly disclosed to the maintainer — who released a fix (**CardanoPress 1.36.1**) crediting Valt. Local and production are updated to 1.36.1 and the interim mitigation is removed. This is a first-party review, still not a substitute for independent external audit at mainnet.
- **Several first-party findings are accepted rather than fixed**, with rationale, and are gated as mainnet prerequisites: database-readable minting credentials, unclamped pagination on public read routes, and transient-based payment idempotency. Rate limiting has since been added to the public write endpoints (§3.1); broader perimeter tooling remains a mainnet item. None of the accepted items is exploitable for financial gain on a testnet.
- **The user-feedback sample is small (n=5) by design.** Valt is a pre-production testnet with a small invited audience, so the analysis is reported as directional qualitative signal with n stated (not percentages), corroborated by behavioural data — not as a statistical result.

